CHAPTER 15

Policies, Procedures, and People

The idea behind this chapter is to examine the people who work for an organization, and how to protect their privacy, while still protecting your infrastructure from *them*! Environmental controls, policies, and procedures can help to protect legitimate individuals and help protect the infrastructure from malicious individuals and social engineers.

This is the last chapter of actual objective content for the Security+ exam, but you will no doubt see several questions on the exam about these topics. The concepts covered in this chapter are a bit of a hodge-podge, covering concepts less about computers, and more on the periphery of technology security, but I have tried to line them up in a way that will make for easy reading and recall. We start with fire suppression and social engineering, which are the first and second sections. That's not to say that policies and procedures are not important, and we do indeed move on to those in the third section.

When going through this chapter, try to keep an open mind as to the different roles a security person might be placed in. Imagine branching out beyond computers, servers, and networks, and developing security for the entire organization and its personnel.

Foundation Topics

Environmental Controls

Although it is usually the duty of the IT director and building management to take care of the installation, maintenance, and repair of environmental controls, you also should have a basic knowledge of how these systems function. Significant concepts include fire suppression, HVAC, and shielding of equipment. By far, the concept a person would spend the most time dealing with when planning a server room is fire suppression.

Fire Suppression

We talked about fire suppression somewhat in Chapter 14, "Redundancy and Disaster Recovery," but we need to dig a bit deeper into the types you can employ, and some of the policies and procedures involved with fire suppression. *Fire suppression* is the process of controlling and/or extinguishing fires to protect an organization's employees, its data, and its equipment. There are basically three types of fire suppression you need to know for the CompTIA Security+ exam: handheld fire extinguisher solutions, sprinkler systems, and special hazard protection systems such as those used in server rooms.

Fire Extinguishers

Be careful when selecting a handheld fire extinguisher. There are several types to choose from; they vary depending on what type of environment you work in. Keep in mind that any one of these will probably cause damage to computers, phones, and other electronics. With only a couple exceptions, these solutions should not be used in a server room or other critical areas of your organization. Here are some of the classifications of fires and their indicators on corresponding fire extinguishers:

Key Topic

- **Fire Class A**—Denoted by a green triangle, this class defines use for ordinary fires consuming solid combustibles such as wood. Think A for "ash" to help remember this type. Water-based extinguishers are suitable for Class A fires only and should not be used in a server room.
- **Fire Class B**—Represented by a red square, this type defines use for flammable liquid and gas fires. I like to remember this by associating B with "butane" because butane is a highly flammable gas.
- **Fire Class C**—Indicated with a blue circle, this type defines use for electrical fires, for example, when an outlet is overloaded. Think C for "copper" as in

copper electrical wiring to aid in memorizing this type. If a fire occurs in a server room, and you don't have a special hazard system (not wise), the multipurpose BC extinguisher (CO2) is the best handheld extinguisher to use. Electrical fires are the most likely type of fire in a server room.

- **Fire Class D**—Designated with a yellow decagon, this type defines use for combustible metal fires such as magnesium, titanium, and lithium. A class D extinguisher is effective in case a laptop's batteries spontaneously ignite. Chemical laboratories and PC repair labs should definitely have one of these available. Metal fires can easily and quickly spread to become ordinary fires. These fire extinguishers are usually yellow; it is one of only a couple that deviate from the standard red color. Also, this is the only other exception when it comes to the use of extinguishers in a critical area of your organization. Because of those two reasons, I like to remember it by associating D with "deviate."
- **Fire Class K**—Symbolized as a black hexagon, this type is for cooking oil fires. This is one type of extinguisher that should be in any kitchen. This is important if your organization has a cafeteria with cooking equipment. Think K for "kitchen" when remembering this type.

The previous bulleted list is not an official standard but is used by most manufacturers of fire extinguishers in the United States. Other countries might have a slightly different system.

In general, the most common type of fire extinguisher used in a building is the multipurpose dry-chemical ABC extinguisher. However, this is extremely messy—it gets into everything! Plus, it can cause corrosion to computer components over time. For server rooms, BC extinguishers are sometimes employed; the most common is the carbon dioxide (CO2) extinguisher. The CO2 extinguisher displaces oxygen, which is needed for a fire to burn, in addition to heat and fuel, which collectively make up the fire triangle. CO2 extinguishers are relatively safe for computer components, especially compared to ABC extinguishers. However, the CO2 extinguisher can possibly cause damage to computer components from electro-static discharge (ESD), although this is rare. Also, if carbon dioxide is released in an enclosed space where people are present, there is a risk of suffocation. If the organization has the money, it is far more preferable to use an ABC-rated Halotron extinguisher in the server room—or better yet, a special hazard protection system.

Older extinguishants, such as Halon, are not used anymore because they are harmful to the environment. Less-developed countries might still use them, but most governments have banned the use of Halon. If you see one of these, it should be replaced with a newer extinguisher that uses environment-safe halocarbon agents such as Halotron or FE-36. These are known as gaseous clean agents that are not

only safe on humans and safe for IT equipment, but are better for the environment as well. Gaseous fire suppression systems are the best for server rooms.

Sprinkler Systems

The most common type of fire sprinkler system consists of a pressurized water supply system that can deliver a high quantity of water to an entire building via a piping distribution system. This is known as a *wet pipe system*. Typical to these systems are sprinkler heads with glass bulbs (often red) or two-part metal links. When a certain amount of predetermined heat reaches the bulb or link, it causes it to shatter or break, applying pressure to the sprinkler cap and initiating the flow of water from that sprinkler and perhaps others in the same zone. The entire system is usually controlled by a valve assembly, often located in the building's basement. Some organizations might have a need for a dry pipe system, which is necessary in spaces where the temperature of that area of the building can be cold enough to freeze the water in a wet pipe system. In this type of system, the pipes are pressurized with air, and water is sent through the system only if necessary; for example, during a fire.

Regardless of the system, an organization should conduct periodic fire drills to simulate a real fire and sprinkler system activation. Afterward, the security administrator should simulate disaster recovery procedures, as detailed in Chapter 14.

Most local municipalities require that organizations possess a sprinkler system that covers all the building's floor space. However, the standard wet pipe or dry pipe systems are not acceptable in server rooms because if set off, they will most likely damage the equipment within. If a person were working in the server room and somehow damaged a pipe, it could discharge; possibly sending a few servers to the scrap heap. Instead, another option for a server room would be a pre-action sprinkler system (and possibly a special hazard protection system in addition to that). A pre-action system is similar to a dry pipe system, but there are requirements for it to be set off such as heat or smoke. So, even if a person were to damage one of the pipes in the sprinkler system, the pre-action system would not be set off.

Special Hazard Protection Systems

I've mentioned several times that your server room contains the livelihood of your organization—its data. If you don't protect the data, you'll be out of a job. One way to protect the server room is by installing a clean agent fire suppression system. Special clean agent fire extinguishers, such as Halotron and FE-36, are recommended for server rooms because they leave no residue after the fire is extinguished, reducing the likelihood of damage to computer systems and networking equipment. Also, they are rated as ABC, so not only can they put out electrical fires, but they can also

put out the ash fire that will most likely ensue. All the other systems mentioned up to this point can easily cause computer failure if they are discharged.

The ultimate solution would be to equip the server room with a special hazard protection, clean agent system, such as an FM-200 system. This gaseous system would be installed in addition to the pre-action system (or other dry pipe system) if the organization can afford it. This system uses a large tank that stores a clean agent fire extinguishant in the form of a liquid. It is sprayed from one or more nozzles in the ceiling of the server room in gas form. A system such as this can put out most classes of fires in seconds. This type of product does not do damage to equipment and can be used safely when people are present. However, most of these systems also employ a *very* loud alarm that tells all personnel to leave the server room; it's usually so loud and abrasive that you are compelled to leave! It is wise to run through fire suppression alarm tests and fire drills, ensuring that the alarm will sound when necessary and that IT personnel know what do to when the alarm sounds, namely, leave. In some cases, these systems will shut the door automatically after a certain timeout. In these cases, procedures should be written out specifying what to do if a fire occurs. Drilling is of utmost importance in these environments to make certain that everyone knows to leave the server room quickly if a fire occurs. Again, after drills have been completed, the appropriate IT personnel should simulate disaster recovery procedures, if necessary. If the system was installed properly and does its job, this simulation should be minimal.

HVAC

HVAC, or heating, ventilating, and air conditioning, is important for server rooms, datacenters, and other technology-oriented areas of your building. Servers run hot—their CPUs can make the temperature inside the case skyrocket. This heat needs to be dissipated and exhausted outside the case. All the heat from servers and other networking equipment is enough to make your server room fry!

To alleviate the situation, organizations install a heavy duty air conditioning system used solely for the server room. Often, the system also includes a humidity control. As we know, static electricity is our enemy. By increasing humidity, we decrease the buildup of static electricity and the chance of ESD. Also, this can enable us to keep our equipment from getting too humid, which can also cause failure. It is important to have this system on its own dedicated circuit that is rated properly.

Because most AC systems use refrigerant, it is important to locate the device and any pipes away from where servers and other equipment will be situated, or use a pipeless system. The controls for this system should be within the server room, perhaps protected by a key code. This way, only authorized IT personnel (who have access to the server room) can change the temperature or humidity. This control can

also be hooked up to the door access system or other monitoring systems to log who made changes and when.

Another way to improve the heat situation is to circulate the air, and one smart way to do this is to install *hot and cold aisles*. To illustrate this concept, imagine that you had several rows of servers inside cabinets, all of which are resting on a raised floor. You would set up the fronts of the cabinets of each row to face each other, forming a cold aisle (the row you would normally walk down to access the servers). The cold air is pumped into this aisle from the raised floor. Since most servers and other IT equipment use front-to-back heat dissipation, the heat should be exhausted out behind the row. That's where the hot aisle is, along with network cables, power cables, and so on. The hot air is exhausted through the raised floor or through exhaust ducts in the ceiling.

Heat is rarely needed in server room, unless the organization's building is in the coldest of environments. This is due to the amount of heat that all the servers give off.

If there is a power failure that cannot be alleviated by use of a UPS and/or backup generator, you might opt to shut down all but the most necessary of systems temporarily. Some organizations enforce this by way of a written policy.

These types of systems are usually beyond the knowledge of the IT people, and any maintenance or repair of such systems should be directed to qualified professionals. Sometimes, the building management is responsible for such systems, but more than likely the organization is responsible for the installation, repair, and maintenance. What's important to know for the exam is that HVAC systems address the need for *availability* of data.

Shielding

We have already established that EMI and RFI can corrupt legitimate signals and can possibly create unwelcome emanations. Shielding can help to prevent these problems. Let's give a few examples:

- **Shielded twisted-pair (STP) cable**—By using STP cable, you employ a shield around the wires inside the cable reducing the levels of interference on the cable segment. This can help with computers suffering from intermittent data loss.
- **HVAC shielding**—By installing a shield around air conditioners and other similar equipment, you end up shielding them, and thereby keep EMI generated by that equipment inside the shield.
- **Faraday cage**—There are several types of Faraday cages. Screened cables such as coaxial cables for TV are basic examples. Booster bags lined with aluminum

foil would be another example. But the term Faraday cage is usually applied to an entire room. If an entire room is shielded, electromagnetic energy cannot pass through the walls in either direction. So, if a person attempts to use a cell phone inside the cage, it will not function properly, because the signal cannot go beyond the cage walls; the cell phone cannot acquire a signal from a cell phone tower. More important, devices such as cell phones, motors, and wireless access points that create electromagnetic fields and are outside the cage cannot disrupt electromagnetic-sensitive devices that reside inside the cage.

By using shielding effectively, you can limit just about any type of interference. Some server rooms are shielded entirely to stop any type of wireless transmissions from entering or exiting the room. This can be an expensive proposition and is more common in datacenters and advanced technology computer rooms. The pinnacle of shielding technology and research is TEMPEST, which according to some organizations stands for Transient ElectroMagnetic Pulse Emanations Standard, though the U. S. government has denied that the word is an acronym at all. The TEMPEST standards (as defined by the U. S. government) deal with the studies into compromising emissions, which are broken down into different levels according to particular environments and strictness of shielding necessary to those environments. Because computers and monitors give off electromagnetic radiation, there is a chance, if a hacker uses the proper antenna, that information could be recorded. TEMPEST is a set of standards that govern the limiting of EM radiation, reducing the chance of the leakage of data. A TEMPEST-certified building can prevent wireless devices from being hacked by wardriving attacks and other similar wireless attacks.

If only it were so easy to shield people from the con: from what we call social engineering.

Social Engineering

Let's discuss a low note in our society. Because that is what social engineering is—a low form of behavior, but an effective one. It is estimated that 1 out of 10 people is conned every year through social engineering, and as many as half of them don't even know it has occurred.

We mentioned in Chapter 1, "Introduction to Security," that *social engineering* is the act of manipulating users into revealing confidential information or performing other actions detrimental to the user. Examples of social engineering are common in everyday life. A basic example would be a person asking for your username and password over the phone; often the person uses flattery to gain the information she seeks. Malicious people use various forms of social engineering in an attempt to steal whatever you have of value: your money, information, identity, confidential

company data, or IT equipment. Social engineering experts use techniques such as bold impersonation, company jargon, embedding of questions, grooming trust, persistence and patience, and even emergency to gain their ends. They use tools such as social networking sites and P2P software to obtain information disclosure. The main reason that social engineering succeeds is due to lack of user awareness. But social engineering can also be effective in environments in which the IT personnel have little training and in public areas, for example, public buildings with shared office space. Let's discuss some of the more common types of social engineering.

Pretexting

Pretexting is when a person invents a scenario, or pretext, in the hope of persuading a victim to divulge information. Preparation and some prior information are often needed before attempting a pretext; impersonation is often a key element. By impersonating the appropriate personnel or third-party entities, a person performing a pretext hopes to obtain records about an organization, its data, and its personnel. IT people and employees should always be on the lookout for impersonators and always ask for identification. If there is any doubt, the issue should be escalated to your supervisor and/or a call should be made to the authorities.

Diversion Theft

Diversion theft is when a thief attempts to take responsibility for a shipment by diverting the delivery to a nearby location. This happens more often than you would think, and millions of dollars worth of IT equipment is stolen in this manner every day. It is important that couriers and other shippers know exactly where they are supposed to be delivering items, and that they are given an organization contact name, number, and possibly security code in case there is any confusion.

Phishing

Phishing is the attempt at fraudulently obtaining private information. A phisher usually masquerades as someone else, perhaps another entity. There are two main differences between phishing and pretexting. First, phishing is usually done by electronic communication, not in person. Second, little information about the target is necessary. A phisher may target thousands of individuals without much concern as to their background. An example of phishing would be an e-mail that requests verification of private information. The e-mail probably leads to a malicious website designed to lure people into a false sense of security to fraudulently obtain information. The website often looks like a legitimate website. A common phishing technique is to pose as a vendor (such as an online retailer or domain registrar) and send the target e-mail confirmations of orders that they supposedly placed.

This is a triple-whammy. First, the orders are obviously fake; a person might say "Hey wait! I didn't place these orders!" and perhaps click the link(s) in the e-mail leading the person to the false web page. Second, if a person thinks it's a legitimate order (perhaps the person does many orders, and the fraudulent one looks like another legitimate one), the person might click a link to track the order, again leading to the bogus web page. Third, once at the web page, the person is asked to enter her credentials for her account (which then leads to credit card fraud and ID theft), and in addition to that the page might have Trojans and other malicious scripts that are delivered to the unsuspecting person on exit. Sheesh, talk about cyber-bullying!

Generally, no information about the target is necessary for a phishing attack. However, some "phishermen" actually target specific groups of people or even specific individuals. This is known as *spear phishing*. And when an attacker targets senior executives (CEOs, CFOs, etc.) it is known as *whaling*. Whaling attacks are much more detailed and require that the attacker know a good deal of information about the target (much of which is freely available on the Internet).

The concept of phishing is also accomplished by telephone. Phone phishing, known as *vishing* works in the same manner as phishing but is initiated by a phone call (often using VoIP systems). The phone call often sounds like a prerecorded message from a legitimate institution (bank, online retailer, donation collector, and so on). The message asks the unsuspecting person for confidential information such as name, bank account numbers, codes, and so on; all under the guise of needing to verify information for the person's protection. It's really the opposite, of course, and many people are caught unawares by these types of scams every day. By using automated systems (such as the ones telemarketers use) vishing can be perpetuated on large groups of people with little effort.

NOTE A similar technique using automated systems is known as *wardialing*. This is when a device (modem or other system) is used to scan a list of telephone numbers and dial them in search of computer systems and fax machines. The technique sifts out the phone numbers associated with voice lines, and the numbers associated with computers. It results in a list that can later be used by other attackers for various purposes.

Many different types of social engineering are often lumped into what is referred to as phishing, but actual phishing for private information is normally limited to e-mail and websites. To defend against this, a phishing filter or add-on should be installed and enabled on the web browser. Also, a person should be trained to realize that institutions will *not* call or e-mail requesting private information. If people are not sure, they should hang up the phone or simply delete the e-mail. A quick way to find

out whether an e-mail is phishing for information is to hover over a link. You will see a URL domain name that is far different from the institution that the phisher is claiming to be, probably a URL located in a distant country.

Hoaxes

A *hoax* is the attempt at deceiving people into believing something that is false. The differences between hoaxes and phishing can be quite gray. However, hoaxes can come in person, or through other means of communication, whereas phishing is generally relegated to e-communication and phone. Although phishing can occur at any time, and with the specific goal of obtaining private information, a hoax can often be perpetuated on holidays or other special days and could be carried out simply for fun. Regardless, they can use up valuable organization resources: e-mail replies, Internet bandwidth used, time spent, and so on. An example of a "harmless" hoax was Google's supposed name change to "Topeka" on April Fools' Day 2010. An example of a financially harmful hoax was the supposed assassination of Bill Gates on April Fools' Day 2003. This hoax led to stock market fluctuations and loss of profit in Asia. Some companies place a time limit on jokes and hoaxes indicating that the affected person has become nonproductive; for example, 3% of the workday.

Pretexting, diversion theft, phishing, and hoaxes are all known as *confidence tricks*, thus the term *con*, and are committed by "bunko" artists. However, there are even lower ways to get access to people's information; these often are used with the previous methods. These include shoulder surfing, eavesdropping, dumpster diving, baiting, and piggybacking.

Shoulder Surfing

Shoulder surfing is when a person uses direct observation to find out a target's password, PIN, or other such authentication information. The simple resolution for this is for the user to shield the screen, keypad, or other authentication requesting devices. A more aggressive approach is to courteously ask the assumed shoulder surfer to move along. Also, private information should never be left on a desk or out in the open. Computers should be locked or logged off when the user is not in the immediate area. Shoulder surfing and the following two sections are examples of no tech hacking.

Eavesdropping

Eavesdropping is when a person uses direct observation to "listen" in to a conversation. This could be a person hiding around the corner or a person tapping into a phone conversation. Soundproof rooms are often employed to stop eavesdropping,

and encrypted phone sessions can also be implemented. For other phone eavesdropping mitigations, see Chapter 7, "Securing Network Media and Devices."

Dumpster Diving

Dumpster diving is when a person literally scavenges for private information in garbage and recycling containers. Any sensitive documents should be stored in a safe place as long as possible. When they are no longer necessary, they should be shredded. (Some organizations incinerate their documents.) Information might not only be found on paper, but also on hard drives or removable media. Proper recycling and/or destruction of hard drives is covered later in this chapter.

Baiting

Baiting is when a malicious individual leaves malware-infected removable media such as a USB drive or optical disc lying around in plain view. It might have an interesting logo or distinctive look about it. When a person takes it and connects it to his computer, the malware infects the computer and attempts to take control of it and/or the network the computer is a member of.

Piggybacking/Tailgating

Piggybacking is when an unauthorized person tags along with an authorized person to gain entry to a restricted area—usually with the person's consent. Tailgating is essentially the same with one difference: it is usually without the authorized person's consent. Both of these can be defeated through the use of mantraps. A *mantrap* is a small space that can usually only fit one person. It has two sets of interlocking doors; the first set must be closed before the other will open, creating a sort of waiting room where people are identified (and cannot escape!) Multifactor authentication is often used in conjunction with a mantrap. For example, using a proximity card and PIN at the first door, and biometric scan at the second. A mantrap is an example of a preventive security control. Turnstiles, double entry doors, and employing security guards are other less expensive (and less effective) solutions to the problem of piggybacking and tailgating and help address confidentiality in general.

Summary of Social Engineering Types

Table 15-1 summarizes the various types of social engineering we have discussed in this section.

Key Topic

Table 15-1 Summary of Social Engineering Types

Type	Description
Pretexting	When a person invents a scenario, or pretext, in the hope of persuading a victim to divulge information.
Diversion theft	When a thief attempts to take responsibility for a shipment by diverting the delivery to a nearby location.
Phishing	The attempt at fraudulently obtaining private information, usually done electronically. Vishing is done by phone. Spear phishing targets specific individuals. Whaling targets senior executives.
Hoax	The attempt at deceiving people into believing something that is false.
Shoulder surfing	When a person uses direct observation to find out a target's password, PIN, or other such authentication information.
Eavesdropping	When a person uses direct observation to "listen" in to a conversation. This could be a person hiding around the corner or a person tapping into a phone conversation.
Dumpster diving	When a person literally scavenges for private information in garbage and recycling containers.
Baiting	When a malicious individual leaves malware-infected removable media such as a USB drive or optical disc lying around in plain view in the hopes that unknowing people will bring it back to their computer and access it.
Piggybacking/ Tailgating	When an unauthorized person tags along with an authorized person to gain entry to a restricted area.

In some cases, social engineering is easier than other more technical ways of hacking information. For example, if a malicious individual wanted a person's password, it might be a lot easier to trick the person into giving her password than to try to crack it.

User Education and Awareness

User education and awareness training are the keys to helping reduce social engineering success. The following is a basic list of rules you can use when training employees:

- Never, under any circumstances, give out any authentication details such as passwords, PINs, company ID, and so on.

- Always shield keypads and screens when entering authentication information.
- Always screen your e-mail and phone calls carefully and keep a log of events.
- Use encryption when possible to protect e-mails and phone calls.
- If there is any doubt as to the legitimacy of a person, e-mail, or phone call, document the situation and escalate it to your supervisor, security, or the authorities.
- Never pick up, and make use of, any removable media.
- Always shred any sensitive information destined for the garbage or recycling.
- Always track and expedite shipments.

When training employees, try to keep them interested; infuse some fun and examples. Use examples of social engineering so that your trainees can make the connection between actual social engineering methods and their defenses. Make them understand that social engineers don't care how powerful an organization's firewall is or how many armed guards the company has. They get past technology and other types of security by exploiting the weaknesses inherent in human nature.

The previous lists of social engineering methods and defenses are in no way finite. There are so many ways to con a person and so many ways to defend against the con. However, some of the best weapons against social engineering, aside from user education and awareness, are policies and procedures, and their constant analysis. The next two sections detail some policies and procedures designed to protect sensitive information.

Legislative and Organizational Policies

There are myriad legislative laws and policies. For the Security+ exam, we are concerned only with a few that affect, and protect, the privacy of individuals. In this section, we cover those and some associated security standards.

More important for the Security+ exam are organizational policies. Organizations usually define policies that concern how data is classified, expected employee behavior, and how to dispose of IT equipment that is no longer needed. These policies begin with a statement or goal that is usually short, to the point, and open-ended. They are normally written in clear language that can be understood by most everyone. They are followed by procedures (or guidelines) that detail how the policy will be implemented.

Table 15-2 shows an example of a basic policy and corresponding procedure.

Table 15-2 Example of a Company Policy

Policy	Procedure
Employees will identify themselves in a minimum of two ways when entering the complex.	**1.** When employees enter the complex, they will first enter a guard room. This will begin the authentication process. **2.** In the guard room, they must prove their identification in two ways: ■ By showing their ID badge to the on-duty guard. ■ By being visible to the guard so that the guard can compare their likeness to the ID badge's photo. The head of the employee should not be obstructed by hats, sunglasses, and so on. In essence, the employee should look similar to the ID photo. If the employee's appearance changes for any reason, that person should contact human resources for a new ID badge. * If guards cannot identify the "employee," they will contact the employee's supervisor, human resources, or security in an attempt to confirm the person's identity. If the employee is not confirmed, they will be escorted out of the building by security. **3.** After the guard has acknowledged the identification, employees will swipe their ID badge against the door scanner to complete the authentication process and gain access to the complex.

Keep in mind that this is just a basic example; technical documentation specialists will tailor the wording to fit the feel of the organization. Plus, the procedure will be different depending on the size and resources of the organization and the type of authentication scheme used, which could be more or less complex. However, the *policy* (which is fairly common) is written in such a way as to be open-ended, allowing for the *procedure* to change over time. We talk about many different policies as they relate to the Security+ exam in this section.

Data Sensitivity and Classification of Information

Sensitive data is information that can result in a loss of security, or loss of advantage to a company, if accessed by unauthorized persons. Often, information is broken down into two groups: classified (which requires some level of security clearance) and nonclassified.

ISO/IEC 27002:2005 (which revises the older ISO/IEC 17799:2005) is a security standard that among other things can aid companies in classifying their data. Although you don't need to know the contents of that document for the Security+

exam, you should have a basic idea of how to classify information. For example, classification of data can be broken down, as shown in Table 15-3.

Table 15-3 Example of Data Sensitivity Classifications

Class	Description
Public information	Information available to anyone.
Internal information	Used internally by a company, but if it becomes public, no critical consequences result.
Confidential information	Information that can cause financial and operational loss to the company.
Secret information	Data that should never become public and is critical to the company.
Top secret information	The highest sensitivity of data, few should have access, security clearance may be necessary. Information is broken into sections on a need-to-know basis.

In this example, loss of public and internal information probably won't affect the company very much. However, unauthorized access, misuse, modification, or loss of confidential, secret, or top secret data can affect users' privacy, trade secrets, financials, and the general security of the company. By classifying data and enforcing policies that govern who has access to what information, a company can limit its exposure to security threats.

Many companies need to be in compliance with specific laws when it comes to the disclosure of information. In the United States there are a few acts you should know about, as shown in Table 15-4. In addition, there are several bills in process that could be passed in the near future regarding data breach notification.

Key Topic

Table 15-4 Acts Passed Concerning the Disclosure of Data and Personally Identifiable Information (PII)

Act	Acronym	Description
Privacy act of 1974	n/a	Establishes a code of fair information practice. Governs the collection, use, and dissemination of personally identifiable information about persons' records maintained by federal agencies.
Sarbanes-Oxley	SOX	Governs the disclosure of financial and accounting information. Enacted in 2002.

Table 15-4 Acts Passed Concerning the Disclosure of Data and Personally Identifiable Information (PII)

Act	Acronym	Description
Health Insurance Portability and Accountability Act	HIPAA	Governs the disclosure and protection of health information. Enacted in 1996.
Gramm-Leach-Bliley Act	GLB	Enables commercial banks, investment banks, securities firms, and insurance companies to consolidate. Protects against pretexting. Individuals need proper authority to gain access to nonpublic information such as Social Security numbers.
California SB 1386	SB 1386	Requires California businesses that store computerized personal information to immediately disclose breaches of security. Enacted in 2003.

Many computer technicians have to deal with SOX and HIPAA at some point in their careers, and although these types of acts create a lot of paperwork and protocol, the expected result is that, in the long run, they will help companies protect their data and keep sensitive information private.

Personnel Security Policies

Most organizations have policies governing employees. The breadth and scope of these policies vary from organization to organization. For example, a small company might have a few pages defining how employees should behave (a code of ethics) and what to do in an emergency. Other larger organizations might go so far as to certify to a particular standard such as ISO 9001:2000 or ISO 9001:2008. This means that the organization will comply with a set of standards that is all-encompassing, covering all facets of the business. An organization would have to be examined and finally accredited by an accrediting certification body to state that it is ISO 9001:2000-certified. This is a rigorous process and is not for the average organization. For many companies, this would create too much documentation and would bog the company down in details and minutia.

We as IT people are more interested in policies that deal with the security of the infrastructure and its employees. As a security administrator, you might deal with procedural documentation specialists, technical documentation specialists, and even outside consultants. You should become familiar with policies and as many procedures as possible, focusing on policies that take security into account, but remember that actual work must take precedence!

Let's define a few types of policies that are common to organizations. We focus on the security aspect of these policies.

Privacy Policies

The Privacy act of 1974 sets many standards when it comes to the security of personally identifiable information (PII). However, most organizations will go further and define their own privacy policy, which explains how users' identities and other similar information will be secured. For example, if an organization has an Internet-based application that internal and external users access, the application will probably retain some of their information—possibly details of their identity. Not only should this information be secured, but the privacy policy should state in clear terms what data is allowed to be accessed, and by whom, as well as how the data will be retained and distributed (if at all). An organization might also enact a policy that governs the labeling of data to ensure that all employees understand what data they are handling, and to prevent the mishandling of confidential information. Before any systems administrators or other personnel gather information about these users, they should consult the privacy policy.

Acceptable Use

Acceptable usage policies (AUP) define the rules that restrict how a computer, network, or other system may be used. They state what users are, and are not, allowed to do when it comes to the technology infrastructure of an organization. Often, an AUP must be signed by the employees before they begin working on any systems. This protects the organization, but it also defines to employees exactly what they should, and should not, be working on. If a director asks a particular employee to repair a particular system that was outside the AUP parameters, the employee would know to refuse. If employees are found working on a system that is outside the scope of their work, and they signed an AUP, it is grounds for termination. As part of an AUP, employees should understand that they are not to take any information or equipment home without express permission from the various parties listed in the policy.

Change Management

Change management is a structured way of changing the state of a computer system, network, or IT procedure. The idea behind this is that change is necessary, but that an organization should adapt with change, and be knowledgeable of it. Any change that a person wants to make must be introduced to each of the heads of various departments that it might affect. They must approve the change before it goes into

effect. Before this happens, department managers will most likely make recommendations and/or give stipulations. When the necessary people have signed off on the change, it should be tested and then implemented. During implementation, it should be monitored and documented carefully.

Because there are so many interrelated parts and people in an IT infrastructure, it is sometimes difficult for the left hand to know what the right hand is doing, or has done in the past. For example, after a network analysis, a network engineer might think that an unused interface on a firewall doesn't necessarily need to exist anymore. But does he know this for sure? Who installed and configured the interface? When was it enabled? Was it ever used? Perhaps it is used only rarely by special customers making a connection to a DMZ; perhaps it is used with a honeynet; or maybe it is for future use or for testing purposes. It would be negligent for the network engineer to simply modify the firewall without at least asking around to find out whether the interface is necessary. More likely, there will be forms involved that require the network engineer to state the reason for change and have it signed by several other people before making the change. In general this will slow down progress, but in the long run it will help to cover the network engineer. People were warned, and as long as the correct people involved have signed off on the procedure or technical change, the network engineer shouldn't have to worry. In a larger organization that complies with various certifications such as ISO 9001:2000, it can be a complex task. IT people should have charts of personnel and department heads. There should also be current procedures in place that show who needs to be contacted in the case of a proposed change.

Separation of Duties/Job Rotation

Separation of duties is when more than one person is required to complete a particular task or operation. This distributes control over a system, infrastructure, or particular task. Job rotation is one of the checks and balances that might be employed to enforce the proper separation of duties. It is when two or more employees switch roles at regular intervals. It is used to increase user insight and skill level, and to decrease the risk of fraud and other illegal activities. Both of these policies are enforced to increase the security of an organization by limiting the amount of control a person has over a situation and by increasing employees' knowledge of what other employees are doing. For more information on these and similar concepts, see Chapter 9, "Access Control Methods and Models."

Mandatory Vacations

Some organizations require employees to take X amount of consecutive days vacation over the course of a year as part of their annual leave. For example, a company

might require an IT director to take five consecutive days vacation at least once per year to force another person into his role for that time period. Although a company might state that this helps the person to rest and focus on his job, and incorporate job rotation, the underlying security concept is that it can help to stop any possible malicious activity that might occur such as fraud, sabotage, embezzlement, and so on. Because IT people are smart, and often access the network remotely in a somewhat unobserved fashion, auditing becomes very important.

Due Diligence

When it comes to information security, *due diligence* is ensuring that IT infrastructure risks are known and managed. An organization needs to spend time assessing risk and vulnerabilities and might state in a policy how it will give due diligence to certain areas of its infrastructure.

Due Care

Due care is the mitigation action that an organization takes to defend against the risks that have been uncovered during due diligence.

Due Process

Due process is the principle that an organization must respect and safeguard personnel's rights. This is to protect the employee from the state and from frivolous lawsuits.

User Education and Awareness Training

With so many possible organizational policies, employees need to be trained to at least get a basic understanding of them. Certain departments of an organization require more training than others. For example, Human Resources personnel need to understand many facets of the business and their corresponding policies, especially policies that affect personnel. HR people should be thoroughly trained in guidelines and enforcement. Sometimes the HR people train management and other employees on the various policies that those trainees are expected to enforce. In other cases, the trainer would be an executive assistant or outside consultant.

Security awareness training is an ongoing process. Different organizations have varying types of security awareness training, and employees with different roles in the organization receive different types of training. This type of training is often coupled with the signing of a user agreement. The user, when signing this, accepts

and acknowledges specific rules of conduct, rules of behavior, and possibly the non-disclosure of any training (known as a nondisclosure agreement or NDA).

All employees should be trained on personally identifiable information (PII). This is information used to uniquely identify, contact, or locate a person. This type of information could be a name, birthday, Social Security number, biometric information, and so on. They should know what identifies them to the organization and how to keep that information secret and safe from outsiders. Another key element of user education is the dissemination of the password policy. They should understand that passwords should be complex, and know the complexity requirements. They should also understand never to give out their password or ask for another person's password to any resource.

IT personnel should be trained on what to do in the case of account changes. For example, temporarily disabling the account of employees when they take a leave of absence or disabling the account (or deleting it, less common) of an employee who has been terminated. All IT personnel should be fluent in the organization's password policy, lockout policy, and other user-related policies so that they can explain them to any other employees.

Some users might need to take additional privacy training, HIPAA training, or other types of security awareness training depending on the type of organization they work for.

Summary of Personnel Security Policies

Table 15-5 breaks down and summarizes the various policy types mentioned in this section.

Key Topic

Table 15-5 Summary of Policy Types

Type	Description
Acceptable use	Policy that defines the rules that restrict how a computer, network, or other system may be used
Change management	A structured way of changing the state of a computer system, network, or IT procedure
Separation of duties	When more than one person is required to complete a task
Job rotation	When a particular task is rotated among a group of employees
Mandatory vacations	When an organization requires employees to take X amount of consecutive days vacation over the course of a year as part of their annual leave
Due diligence	Ensuring that IT infrastructure risks are known and managed

Type	Description
Due care	The mitigation action that an organization takes to defend against the risks that have been uncovered during due diligence
Due process	The principle that an organization must respect and safeguard personnel's rights

How to Deal with Vendors

Before we begin, I should mention that the following information is *not* intended as legal advice. Before signing any contracts, an organization should strongly consider consulting with an attorney.

An organization often has in-depth policies concerning vendors. I can't tell you how many times I've seen issues occur because the level of agreement between the organization and the vendor was not clearly defined. A proper *service level agreement (SLA)* that is analyzed by the organization carefully before signing can be helpful. A basic service contract is usually not enough; a service contract with an SLA will have a section within it that formally and clearly defines exactly what a vendor is responsible for and what the organization is responsible for—a demarcation point so to speak. It might also define performance expectations and what the vendor will do if a failure of service occurs, timeframes for repair, backup plans, and so on. To benefit the organization, these will usually be legally binding and not informal. Due to this, it would benefit the organization to scrutinize the SLA before signing, and an organization's attorney should be involved in that process.

For instance, a company might use an ISP for its T3 connection. The customer will want to know what kind of fault-tolerant methods are on hand at the ISP and what kind of uptime they should expect, which should be monitored by a network admin. The SLA might have some sort of guarantee of measurable service that can be clearly defined. Perhaps a minimum level of service and a target level of service. Before signing an SLA such as this, it is recommended that an attorney, the IT director, and other organizational management review the document carefully and make sure that it covers all the points required by the organization.

How to Dispose of Computers and Other IT Equipment Securely

Organizations might opt to recycle computers and other equipment or donate them. Rarely do organizations throw away equipment. It might be illegal to do so depending on your location and depending on what IT equipment is to be thrown away. The first thing an IT person should do is consult the organization's policy regarding computer disposal, and if necessary, consult local municipal guidelines.

A basic example of a policy and procedure that an organization enforces might look like the following:

Policy: Recycle or donate IT equipment that has been determined to be outdated and nonproductive to the company.

Step 1. Define what equipment is to be disposed of.

Step 2. Obtain a temporary storage place for the equipment.

Step 3. Have appropriate personnel analyze the equipment.

- Verify whether the equipment is indeed outdated and whether it can be used somewhere else in the organization.
- If a device can be used in another area of the organization, it should be formatted, flashed, or otherwise reset back to the original default, and then transported to its new location. See the procedure named "Resetting a device or computer to factory defaults" within document S-536 for more information.
- If a device cannot be reused in the organization, move to Step 4.

Step 4. Sanitize the devices or computers.

- Check for any removable media inside, or connected to, the computer. These should be analyzed and recycled within the organization if possible.
- Remove any RAM, label it with the computer name, and store it.
- Remove the hard drive, sanitize it, and store it.
- Reset any BIOS or other passwords to the default setting.

Step 5. Recycle or donate the item as required. See the procedure named "Recycling and donating IT equipment" within document S-536 for more information on whether to select recycling or donating.

Again, this is just an example of a basic recycle policy and procedure, but it gives you an idea of the type of method an organization might employ to best make use of its IT equipment and to organize the entire recycling/donating process.

In Step 4, we mentioned to "sanitize the hard drive." Sanitizing the hard drive is a common way of removing data but not the only one. The way data is removed might vary depending on its proposed final destination. Data removal is the most important element of computer recycling. Proper data removal goes far beyond file deletion or the formatting of digital media. The problem with file deletion/formatting is data remanence, or the residue, that is left behind, from which re-creation of files can be accomplished with the use of software such as SpinRite or Ontrack Data

Recovery. Companies typically employ one of three options when met with the prospect of data removal:

- **Clearing**—This is the removal of data with a certain amount of assurance that it cannot be reconstructed. The data is actually recoverable with special techniques. In this case, the media is recycled and used within the company again. The data wiping technique (also known as shredding) is used to clear data from media by overwriting new data to that media. In some cases, patterns of ones and zeros are written to the entire drive. Several software programs are available to accomplish this.
- **Purging**—Also known as sanitizing, this is once again the removal of data, but this time, it's done in such a way so that it cannot be reconstructed by any known technique; in this case the media is released outside the company. Special bit-level erasure software (or other means) is employed to completely destroy all data on the media. It is also possible to degauss the disk, which renders the data unreadable but might also cause physical damage to the drive.
- **Destruction**—This is when the storage media is physically destroyed through pulverizing, incineration, and so on. At this point, the media can be disposed of in accordance with municipal guidelines.

The type of data removal used will be dictated by the data stored on the drive. If there is no personally identifiable information, or other sensitive information, it might simply be cleared and released outside the company. But in many cases, organizations will specify purging of data if the drive is to leave the building. In cases where a drive previously contained confidential or top secret data, the drive will usually be destroyed.

Incident Response Procedures

Incident response is a set of procedures that an investigator follows when examining a computer security incident. Incident response procedures are a part of computer security *incident management*, which can be defined as the monitoring and detection of security events on a computer network and the execution of proper responses to those security events.

However, often, IT employees of the organization discover the incident. Sometimes they act as the investigators also. It depends on the resources and budget of the organization. So it is important for the IT personnel to be well briefed on policies regarding the reporting and disclosure of incidents.

Don't confuse an incident with an event. An example of a single event might be a single stop error on a Windows computer. In many cases, the BSOD won't occur again, and regardless, it has been logged in the case that it does. The event should

be monitored, but that is about all. An example of an incident would be when several DDOS attacks are launched at an organization's web servers over the course of a work day. This will require an incident response team that might include the security administrator, IT or senior management, and possibly a liaison to the public and local municipality.

The seven main steps of the incident response process can be summed up simply as the following:

Key Topic

Step 1. **Identification**—The recognition of whether an event that occurs should be classified as an incident.

Step 2. **Containment**—Isolating the problem. For example, if it is a network attack, the attacker should be extradited to a padded cell. Or if only one server has been affected so far by a worm or virus, it should be physically disconnected from the network.

Step 3. **Evidence gathering**—Evidence of the incident is gathered by security professionals in a way that preserves the evidence's integrity.

Step 4. **Investigation**—Investigators within the organization and perhaps consultants ascertain exactly what happened and why.

Step 5. **Eradication**—Removal of the attack, threat, and so on.

Step 6. **Recovery**—Retrieve data, repair systems, re-enable servers, networks, and so on.

Step 7. **Documentation & Monitoring**—Document the process and make any changes to procedures and processes that are necessary for the future. Damage and loss should be calculated and that information should be shared with the accounting department of the organization. The affected systems should be monitored for any repercussions.

However, an organization might have more or fewer steps, and their procedures might vary. An organization's typical incident response policy and procedures generally detail the following:

- **Initial incident management process**—This includes who first found the problem, tickets, and various levels of change controls. It also defines first responders (also known as first-level responders) who perform preliminary analysis of the incident data and determine whether the incident is actually an incident or just an event, and the criticality of the incident.
- **Emergency response detail**—If the incident is deemed to be an emergency, this details how the event is escalated to an emergency incident. It also specifies a coordinator of the incident, in which the incident team will meet, lock-

down procedures, containment of the incident, repair and test of systems, and further investigation procedures to find the culprit (if there is one).

- **Computer forensics**—The incident response policy might define how computer forensics (or digital forensics) should be carried out. It might detail how information is to be deciphered from a hard disk or other device. Often, it dictates the use of hard drive hashing so that computer forensics experts can identify tampering by outside entities. It might also specify a list of rules to go by when investigating what an attacker did. For example, forensics investigators verify the integrity of data to ensure that it has not been tampered with. It is important that computer forensics investigations are carried out properly in the case that legal action is taken. Policies detailing the proper collection and preservation of evidence can be of assistance when this is the case.
- **Collection and preservation of evidence**—Sherlock Holmes based his investigations on traditional clues such as footprints, fingerprints, and cigar ash. Analogous to this, a security investigator needs to collect log files, alerts, captured packets, and so on, and preserve the integrity of this information by retaining forensic images of data. Modification of any information or image files during the investigative process will most likely void its validity in a court of law. One way to preserve evidence properly is to establish a chain of custody—the chronological documentation or paper trail of evidence. This is something that should be set up immediately at the start of an investigation; it documents who had custody of evidence all the way up to litigation or a court trial (if necessary) and verifies that the evidence has not been modified. An incident response policy lists proper procedures when it comes to the procurement of evidence.
- **Damage and loss control**—The incident response policy also covers how to stop the spread of damage to other IT systems and how to minimize or completely curtail loss of data.

Of course, this type of policy will be much more in depth, specify exact procedures, and vary in content from organization to organization. To find out more about common practices and standards for incident response, see the ISO/IEC 27002:2005 standard. Due to the length and breadth of the information, there is far too much to cover in this book. (I left a link at the end of the chapter to this. You can also search the Internet for one of several documents that whittles down the content to a more manageable size—but still pretty hefty reading material!) The Security+ exam expects you to know only the basics of incident response.

Now, I know what you are thinking. With all these policies and procedures in place, how does anything ever get done?! And how do incidents get analyzed quickly enough so as not to become a disaster? Well, training is important. Personnel need

to be trained quickly and efficiently without getting too much into the minutia of things. They also need to be trained to *take action* quickly. By narrowing down an organization's policies to just what an employee needs to know, you can create a short but sweet list of key points for the employee to remember. Need-to-know is in itself an important security concept in companies. It is designed as much to hide information from people as it is to prevent information overload. For example, if a person were choking, the information you want to know is how to perform the Heimlich Maneuver; you don't care why a person chokes, what the person ate for breakfast, or how specifically the maneuver works. This concept helps when there is an event or incident; the employees don't need to sift through wads of policies to find the right action to take, because they are on a need-to-know basis and will quickly execute what they have been trained to do. Need-to-know also comes into play when confidential or top secret information is involved. In classified environments, top secret information is divided into pieces, only some of which particular people have access to.

So that wraps up this chapter about policies, procedures, and people. It was a bit helter-skelter as far as the listing of content, but in a way, all the concepts are intertwined. When you are involved in any type of policing, investigative work, or other security-based IT work, consider the safety of personnel and data and the integrity of organizational information.

Exam Preparation Tasks

Review Key Topics

Review the most important topics in the chapter, noted with the Key Topic icon in the outer margin of the page. Table 15-6 lists a reference of these key topics and the page number on which each is found.

Key Topic

Table 15-6 Key Topics for Chapter 15

Key Topic Element	Description	Page Number
Bulleted list	Fire Extinguisher Types	510
Table 15-1	Summary of Social Engineering Types	520
Table 15-4	Acts Passed Concerning the Disclosure of Data and PII	523
Table 15-5	Summary of Policy Types	528
Numbered list	Seven Steps of Incident Response Process	532

Complete Tables and Lists from Memory

Print a copy of Appendix A, "Memory Tables," (found on the DVD), or at least the section for this chapter, and complete the tables and lists from memory. Appendix B, "Memory Tables Answer Key," also on the DVD, includes completed tables and lists to check your work.

Define Key Terms

Define the following key terms from this chapter, and check your answers in the glossary:

fire suppression, wet pipe sprinkler system, pre-action sprinkler system, special hazard protection system, hot and cold aisles, pretexting, diversion theft, phishing, vishing, spear phishing, whaling, hoax, shoulder surfing, eavesdropping, dumpster diving, baiting, piggybacking, tailgating, mantrap, acceptable use, mandatory vacations, due diligence, due care, due process, change management, personally identifiable information (PII), service level agreement (SLA), first responders, chain of custody, incident response, incident management

View Recommended Resources

- ISO/IEC 27002:2005: Information technology—Security techniques—Code of practice for information security management: www.iso.org/iso/catalogue_detail?csnumber=50297
- Privacy Act of 1974: http://epic.org/privacy/laws/privacy_act.html and www.justice.gov/opcl/privstat.htm
- SpinRite data recovery software: www.grc.com/sr/spinrite.htm
- Ontrack Data Recovery: www.ontrackdatarecovery.com/file-recovery-software/
- Journal of Digital Forensics, Security and Law: www.jdfsl.org/
- The International Journal of Forensic Computer Science: www.ijofcs.org/
- CISSP Video Mentor: Shon Harris: www.pearsonitcertification.com/store/product.aspx?isbn=0789740303

Answer Review Questions

Answer the following review questions. You can find the answers at the end of this chapter.

1. Which method would you use if you were disposing hard drives as part of a company computer sale?
   - **A.** Destruction
   - **B.** Purging
   - **C.** Clearing
   - **D.** Formatting

2. Which of these governs the disclosure of financial data?
   - **A.** SOX
   - **B.** HIPAA
   - **C.** GLB
   - **D.** Top secret

3. Jeff wants to employ a Faraday cage. What will this accomplish?
   - **A.** It will increase the level of wireless encryption.
   - **B.** It will reduce data emanations.
   - **C.** It will increase EMI.
   - **D.** It will decrease the level of wireless emanations.

4. If a fire occurs in the server room, which device is the best method to put it out?
   - **A.** Class A extinguisher
   - **B.** Class B extinguisher
   - **C.** Class C extinguisher
   - **D.** Class D extinguisher

5. What device will not work in a Faraday cage? (Select the best two answers.)
   - **A.** Cell phones
   - **B.** Computers
   - **C.** Pagers
   - **D.** TDR

6. You go out the back door of your building and noticed someone looking through your company's trash. If this person were trying to acquire sensitive information, what would this attack be known as?
   - **A.** Browsing
   - **B.** Dumpster diving
   - **C.** Phishing
   - **D.** Hacking

7. You are told by your manager to keep evidence for later use at a court proceeding. Which of the following should you document?
   - **A.** Disaster recovery plan
   - **B.** Chain of custody
   - **C.** Key distribution center
   - **D.** Auditing

8. Which law protects your Social Security number and other pertinent information?
   - **A.** HIPAA
   - **B.** SOX
   - **C.** The National Security Agency
   - **D.** The Gramm-Leach-Bliley Act

9. User education can help to defend against which of the following? (Select the three best answers.)
   - **A.** Social engineering
   - **B.** Phishing
   - **C.** Rainbow Tables
   - **D.** Dumpster diving

10. Which of these is an example of social engineering?
    - **A.** Asking for a username and password over the phone
    - **B.** Using someone else's unsecured wireless network
    - **C.** Hacking into a router
    - **D.** Virus

11. What is the most common reason that social engineering succeeds?

- **A.** Lack of vulnerability testing
- **B.** People share passwords
- **C.** Lack of auditing
- **D.** Lack of user awareness

12. Which of the following is not one of the steps of the incident response process?

- **A.** Eradication
- **B.** Recovery
- **C.** Containment
- **D.** Nonrepudiation

13. In which two environments would social engineering attacks be most effective? (Select the two best answers.)

- **A.** Public building with shared office space
- **B.** Company with a dedicated IT staff
- **C.** Locked building
- **D.** Military facility
- **E.** An organization whose IT personnel have little training

14. Of the following definitions, which would be an example of eavesdropping?

- **A.** Overhearing parts of a conversation
- **B.** Monitoring network traffic
- **C.** Another person looking through your files
- **D.** A computer capturing information from a sender

15. Your company expects its employees to behave in a certain way. How could a description of this behavior be documented?

- **A.** Chain of custody
- **B.** Separation of duties
- **C.** Code of ethics
- **D.** Acceptable use policy

16. You are a forensics investigator. What is the most important reason for you to verify the integrity of acquired data?
    - **A.** To ensure that the data has not been tampered with
    - **B.** To ensure that a virus cannot be copied to the target media
    - **C.** To ensure that the acquired data is up-to-date
    - **D.** To ensure that the source data will fit on the target media

17. Of the following, which type of fire suppression can prevent damage to computers and servers?
    - **A.** Class A
    - **B.** Water
    - **C.** CO2
    - **D.** ABC extinguishers

18. You are the security administrator for your organization. You have just identified a malware incident. Of the following, what should be your first response?
    - **A.** Containment
    - **B.** Removal
    - **C.** Recovery
    - **D.** Monitoring

19. A man pretending to be a data communications repair technician enters your building and states that there is networking trouble and he needs access to the server room. What is this an example of?
    - **A.** Man-in-the-middle attack
    - **B.** Virus
    - **C.** Social engineering
    - **D.** Chain of custody

20. Employees are asked to sign a document that describes the methods of accessing a company's servers. Which of the following best describes this document?
    - **A.** Acceptable use policy
    - **B.** Chain of custody
    - **C.** Incident response
    - **D.** Privacy Act of 1974

21. One of the developers for your company asks you what he should do before making a change to the code of a program's authentication. Which of the following processes should you instruct him to follow?

- **A.** Chain of custody
- **B.** Incident response
- **C.** Disclosure reporting
- **D.** Change management

22. As a network administrator, one of your jobs is to deal with Internet service providers. You want to ensure that the provider guarantees end-to-end traffic performance. What is this known as?

- **A.** SLA
- **B.** VPN
- **C.** DRP
- **D.** WPA

23. Turnstiles, double entry doors, and security guards are all preventative measures for what kind of social engineering?

- **A.** Dumpster diving
- **B.** Impersonation
- **C.** Piggybacking
- **D.** Eavesdropping

24. When it comes to security policies, what should HR personnel be trained in?

- **A.** Maintenance
- **B.** Monitoring
- **C.** Guidelines and enforcement
- **D.** Vulnerability assessment

25. In a classified environment, clearance to top secret information that enables access to only certain pieces of information is known as what?

- **A.** Separation of duties
- **B.** Chain of custody
- **C.** Nonrepudiation
- **D.** Need to know

26. In addition to bribery and forgery, which of the following are the most common techniques that attackers used to socially engineer people? (Select the two best answers.)

- **A.** Flattery
- **B.** Assuming a position of authority
- **C.** Dumpster diving
- **D.** Whois search

27. What is documentation that describes minimum expected behavior known as?

- **A.** Need to know
- **B.** Acceptable usage
- **C.** Separation of duties
- **D.** Code of ethics

28. You are the security administrator for your company. You have been informed by human resources that one of the employees in accounting has been terminated. What should you do?

- **A.** Delete the user account.
- **B.** Speak to the employee's supervisor about the person's data.
- **C.** Disable the user account.
- **D.** Change the user's password.

29. You need to protect your datacenter from unauthorized entry at all times. Which is the best type of physical security to implement?

- **A.** Mantrap
- **B.** Video surveillance
- **C.** Nightly security guards
- **D.** 802.1X

30. Which of the following targets specific people?

- **A.** Pharming
- **B.** Phishing
- **C.** Vishing
- **D.** Spear phishing

31. Why would you implement password masking?

- **A.** To deter tailgating
- **B.** To deter shoulder surfing
- **C.** To deter impersonation
- **D.** To deter hoaxes

32. Your organization already has a policy in place that bans flash drives. What other policy could you enact to reduce the possibility of data leakage?

- **A.** Disallow the saving of data to a network share
- **B.** Enforce that all work files have to be password protected
- **C.** Disallow personal music devices
- **D.** Allow unencrypted HSMs

33. Which of the following requires special handling and policies for data retention and distribution?

- **A.** Phishing
- **B.** Personal electronic devices
- **C.** SOX
- **D.** PII

34. A targeted e-mail attack is received by your organization's CFO. What is this an example of?

- **A.** Vishing
- **B.** Phishing
- **C.** Whaling
- **D.** Spear phishing

35. One of the accounting people is forced to change roles with another accounting person every three months. What is this an example of?

- **A.** Least privilege
- **B.** Job rotation
- **C.** Mandatory vacation
- **D.** Separation of duties

36. Which of the following environmental variables reduces the possibility of static discharges (ESD)?
    - **A.** Humidity
    - **B.** Temperature
    - **C.** EMI
    - **D.** RFI

37. You have been ordered to implement a secure shredding system as well as privacy screens. What two attacks is your organization attempting to mitigate?
    - **A.** Shoulder surfing
    - **B.** Impersonation
    - **C.** Phishing
    - **D.** Dumpster diving
    - **E.** Tailgating

Answers and Explanations

1. **B.** Purging (or sanitizing) removes all the data from a hard drive so that it cannot be reconstructed by any known technique. If a hard drive were destroyed, it wouldn't be of much value at a company computer sale. Clearing is the removal of data with a certain amount of assurance that it cannot be reconstructed; this method is usually used when recycling the drive within the organization. Formatting is not nearly enough to actually remove data because it leaves data residue, which can be used to reconstruct data.
2. **A.** SOX, or Sarbanes-Oxley, governs the disclosure of financial and accounting data. HIPAA governs the disclosure and protection of health information. GLB, or the Gramm-Leach-Bliley Act of 1999, enables commercial banks, investment banks, securities firms, and insurance companies to consolidate. Top secret is a classification given to confidential data.
3. **B.** The Faraday cage will reduce data emanations. The cage is essentially an enclosure (of which there are various types) of conducting material that can block external electric fields and stop internal electric fields from leaving the cage, thus reducing or eliminating data emanations from such devices as cell phones.
4. **C.** When you think Class C, think Copper. Extinguishers rated as Class C can suppress electrical fires, which are the most likely kind in a server room.

5. **A and C.** Signals cannot emanate outside a Faraday cage. Therefore, cell phones and pagers will not work inside the Faraday cage.
6. **B.** Dumpster diving is when a person goes through a company's trash to find sensitive information about an individual or a company. Browsing is not an attack but something you do when connected to the Internet. Phishing is known as acquiring sensitive information through the use of electronic communication. Nowadays, hacking is a general term used with many different types of attacks.
7. **B.** A chain of custody is the chronological documentation or paper trail of evidence. A disaster recovery plan details how a company will recover from a disaster with such methods as backup data and sites. A key distribution center is used with the Kerberos protocol. Auditing is the verification of logs and other information to find out who did what action and when and where.
8. **D.** The Gramm-Leach-Bliley Act protects private information such as Social Security numbers. HIPAA deals with health information privacy. SOX, or the Sarbanes Oxley Act of 2002, applies to publicly held companies and accounting firms and protects shareholders in the case of fraudulent practices.
9. **A, B, and D.** Rainbow Tables are lookup tables used when recovering passwords. User education and awareness can help defend against social engineering attacks, phishing, and dumpster diving.
10. **A.** Social engineering is the practice of obtaining confidential information by manipulating people. Using someone else's network is just theft. Hacking into a router is just that, hacking. And a virus is a self-spreading program that may or may not cause damage to files and applications.
11. **D.** User awareness is extremely important when attempting to defend against social engineering attacks. Vulnerability testing and auditing are definitely important as part of a complete security plan but will not necessarily help defend against social engineering and definitely not as much as user awareness training. People should not share passwords.
12. **D.** Nonrepudiation, although an important part of security, is not part of the incident response process. Eradication, containment, and recovery are all parts of the incident response process.
13. **A and E.** Public buildings, shared office space, and companies with employees that have little training are all environments in which social engineering attacks are common and would be most successful. Social engineering will be less successful in secret buildings, buildings with a decent level of security such as military facilities, and organizations with dedicated and well-trained IT staff.

14. **A.** Eavesdropping is when people listen to a conversation that they are not part of. A security administrator should keep in mind that someone could always be listening and to try to protect against this.
15. **C.** The code of ethics describes how a company wants its employees to behave. A chain of custody is a legal and chronological paper trail. Separation of duties means that more than one person is required to complete a job. Acceptable use policy is a set of rules that restrict how a network or a computer system may be used.
16. **A.** Before analyzing any acquired data, you need to make sure that the data has not been tampered with, so you should verify the integrity of the acquired data before analysis.
17. **C.** CO2 is the best answer that will prevent damage to computers because it is air-based, not water-based. CO2 displaces oxygen. Fire needs oxygen; without it the fire will go out. All the others have substances that can damage computers. However, because CO2 can possibly cause ESD damage, the best solution in a server room would be Halotron or FE-36.
18. **A.** Most organizations' incident response procedures will specify that containment of the malware incident should be first. Next would be the removal, then recovery of any damaged systems, and finally monitoring that should actually be going on at all times.
19. **C.** Any person pretending to be a data communications repair person would be attempting a social engineering attack.
20. **A.** Acceptable use (or usage) policies set forth the principles for using IT equipment such as computers, servers, and network devices. Employees are commonly asked to sign such a document that is a binding agreement that they will try their best to adhere to the policy.
21. **D.** He should follow the change management process as dictated by your company's policies and procedures. This might include filing forms in paper format and electronically, and notifying certain departments of the proposed changes before they are made.
22. **A.** An SLA, or service-level agreement, is the agreement between the Internet service provider and you, finding how much traffic you are allowed, and what type of performance you can expect. A VPN is a virtual private network. A DRP is a disaster recovery plan. And WPA is Wi-Fi protected access.

23. **C.** Turnstiles, double entry doors, and security guards are all examples of preventative measures that attempt to defeat piggybacking. Dumpster diving is when a person looks through a coworker's trash or a building's trash to retrieve information. Impersonation is when a person attempts to represent another person possibly with the other person's identification. Eavesdropping is when a person overhears another person's conversation.

24. **C.** Human resource personnel should be trained in guidelines and enforcement. A company's standard operating procedures will usually have more information about this. However, a security administrator might need to train these employees in some areas of guidelines and enforcement.

25. **D.** In classified environments, especially when accessing top secret information, a person can get access to only what they need to know.

26. **A and C.** The most common techniques that attackers use to socially engineer people include flattery, dumpster diving, bribery, and forgery. Although assuming a position of authority is an example of social engineering, it is not one of the most common. A WHOIS search is not necessarily malicious; it can be accomplished by anyone and can be done for legitimate reasons. This type of search can tell a person who runs a particular website or who owns a domain name.

27. **D.** A code of ethics is documentation that describes the minimum expected behavior of employees of a company or organization. Need to know deals with the categorizing of data and how much an individual can access. Acceptable usage defines how a user or group of users may use a server or other IT equipment. Separation of duties refers to a task that requires multiple people to complete.

28. **C.** When an employee has been terminated, the employee's account should be disabled, and the employee's data should be stored for a certain amount of time, which should be dictated by the company's policies and procedures. There is no need to speak to the employee's supervisor. It is important not to delete the user account because the company may need information relating to that account later on. Changing the user's password is not enough; the account should be disabled.

29. **A.** Mantraps are the best solution listed—they are the closest to foolproof of the listed answers. Mantraps (if installed properly) are strong enough to keep a human inside until he completes the authentication process or is escorted off the premises. This is a type of preventive security control meant to stop tailgating and piggybacking. Video surveillance will not prevent an unauthorized person from entering your datacenter, it is a detective security control. Security guards are a good idea, but if they only work at night, then they can't prevent unauthorized access at all times. 802.1X is an excellent authentica-

tion method, but it is logically implemented as software and devices; it is not a physical security control.

30. **D.** Spear phishing is a targeted attack unlike regular phishing, which usually works by contacting large groups of people. Pharming is when a website's traffic is redirected to another, illegitimate, website. Vishing is the phone/VoIP version of phishing.

31. **B.** Password masking is when the characters a user types into a password field are replaced, usually by asterisks. This is done to prevent shoulder surfing. Tailgating is when an unauthorized person follows an authorized person into a secure area, without the second person's consent. Impersonation is when a person masquerades as another authorized user. A hoax is an attempt at deceiving people into believing something that is false.

32. **C.** By creating a policy that disallows personal music devices, you reduce the possibility of data leakage. This is because many personal music devices can store data files, not just music files. This could be a difficult policy to enforce since smartphones can play music and store data. That's when you need to configure your systems so that those devices cannot connect to the organization's network. DLP devices would also help to prevent data leakage. Network shares are part of the soul of a network, without them, there would be chaos as far as stored data. If network shares are configured properly, there shouldn't be much of a risk of data leakage. Password protecting files is something that would be hard to enforce, and the encryption used could very easily be subpar and easily cracked. HSMs are inherently encrypted; that is their purpose. To allow an HSM would be a good thing, but there are no unencrypted HSMs.

33. **D.** PII (personally identifiable information) must be handled and distributed carefully to prevent ID theft and fraud. Phishing is the attempt at obtaining information fraudulently. Personal electronic devices should be protected and secured but do not require special policies. SOX (Sarbanes Oxley) is an act that details the disclosure of banking information.

34. **C.** Whaling is a type of spear phishing that targets senior executives such as CFOs. Regular old phishing does not target anyone, but instead tries to contact as many people as possible until an unsuspecting victim can be found. Vishing is the telephone-based version of phishing. Spear phishing does target individuals but not senior executives.

35. **B.** Job rotation is when people switch jobs, usually within the same department. This is done to decrease the risk of fraud. It is closely linked with separation of duties, which is when multiple people work together to complete a task; each person is given only a piece of the task to accomplish. Least privilege is when a process (or a person) is given only the bare minimum needed to complete its function. Mandatory vacations are when an employee is forced to take X amount of consecutive days vacation away from the office.

36. **A.** Humidity (if increased) can reduce the chance of static discharges. Temperature does not have an effect on computer systems (within reason). EMI and RFI are types of interference that in some cases could possibly increase the chance of static discharge.

37. **A. and D.** The privacy screens are being implemented to prevent shoulder surfing. The secure shredding system is being implemented to mitigate dumpster diving. Impersonation is when an unauthorized person masquerades as a legitimate, authorized person. Phishing is when an attacker attempts to fraudulently obtain information through e-mail scams. Tailgating is when a person (without proper credentials) attempts to gain access to an unauthorized area by following someone else in.